Overview

"Secrets in Source 2" is a beginner-friendly web challenge demonstrating the classic flaw of **Security through Obscurity**. The challenge highlights why relying on client-side restrictions (like disabling right-click or shortcuts) fails to protect sensitive resources.

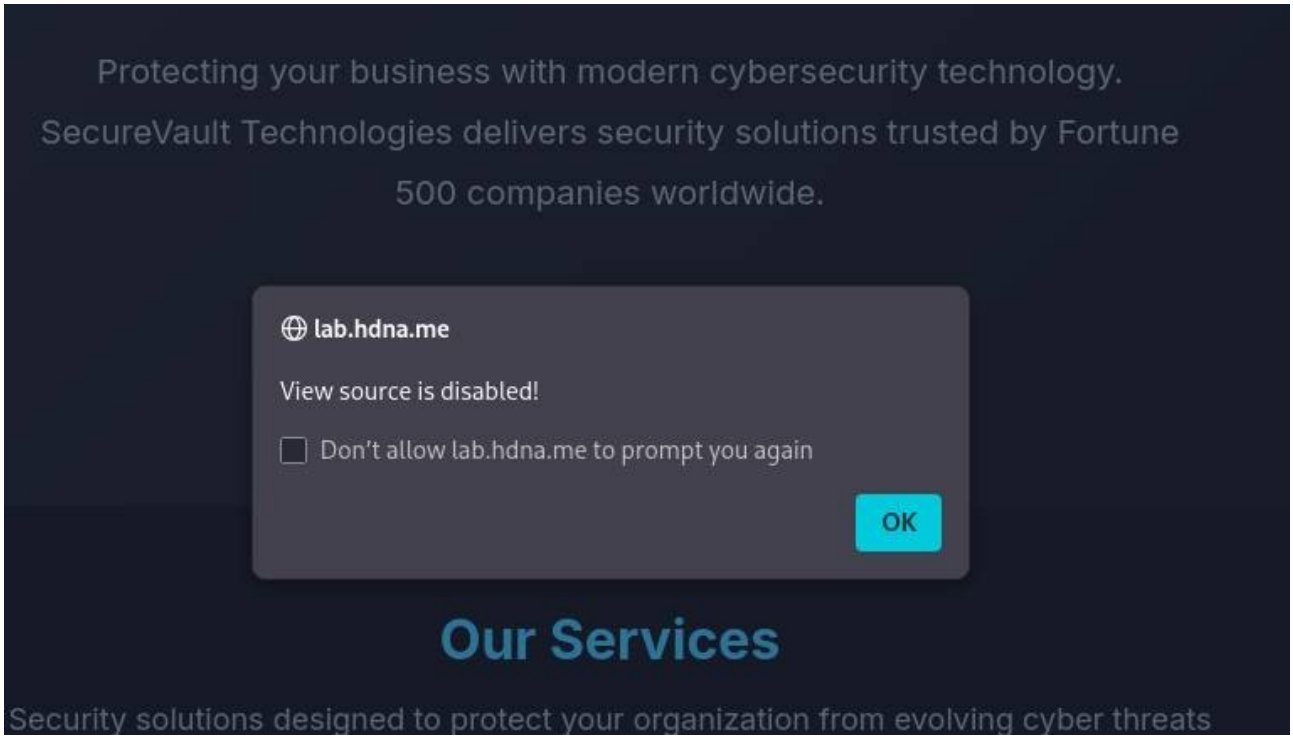
Reconnaissance

Upon opening the lab URL, the page appears restricted at first glance:

- Right-clicking is disabled.



- Keyboard shortcuts like `Ctrl + U` (View Source) are blocked by frontend scripts.



While these measures might deter a casual user, they offer zero real security against someone inspecting the underlying traffic or browser behavior.

Exploitation

To bypass the client-side restrictions and view the source code, there are a couple of straightforward approaches:

Method 1: Using the `view-source:` Prefix

Modern browsers allow you to bypass frontend scripts by prepending `view-source:` directly to the URL in the address bar:

```
view-source:https://lab.hdna.me/145-secrets-in-source-2
```

Method 2: Command Line Tools (curl or wget)

Alternatively, you can fetch the raw HTML directly from the terminal without interacting with the browser's DOM restrictions:

```
curl https://lab.hdna.me/145-secrets-in-source-2
          or
wget -qO- https://lab.hdna.me/145-secrets-in-source-2
```

Finding the Secret

Inspecting the raw HTML source reveals an HTML comment left behind by the development team:

```
“<!-- TODO(devops): /s3cr3t_v4u1t_92x7h/flag.txt is still world-readable, lock it down before launch -->”
```

The comment explicitly points to a sensitive file path that was left accessible on the server.

Capturing the Flag

Appending the discovered path (`/s3cr3t_v4u1t_92x7h/flag.txt`) to the base URL retrieves the file and exposes the flag:

https://lab.hdna.me/145-secrets-in-source-2/s3cr3t_v4u1t_92x7h/flag.txt

Key Takeaways

1. **Client-side controls are not security:** Disabling right-click or keyboard shortcuts only stops casual users. Anyone can inspect network traffic or view source code using developer tools, command-line utilities, or browser prefixes.
2. **Never leave sensitive comments in production:** Development notes, hidden endpoints, and credentials left in HTML comments or source files are prime targets for automated scanners and attackers.